

Stripe Responsibility Matrix

Version: 1.1

Date: 2026-02-25

Status: IN EFFECT

Applies to: Impact Amplifier (vote purchase) — Stripe Checkout integration

Related: Dispute Handling Procedure (dispute-handling-procedure)

1. Parties

Party	Legal entity	Role
Sharity	Sharity Donation Organizing Foundation + Sharity Mobile Application Zrt.	Merchant — the Stripe account owner
Stripe	Stripe Payments Europe, Limited (Dublin, Ireland)	Payment processor
User	Natural person or company	Donor — pays via Stripe Checkout

2. Responsibility Matrix

2.1 Payment Flow

Activity	Sharity	Stripe	Notes
Checkout Session creation (REST → Stripe API)	✓	—	Server-side API call
Payment page rendering (hosted checkout)	—	✓	Stripe hosted — card data does not touch the Sharity server
Card data handling (PCI-DSS)	—	✓	Sharity scope: PCI SAQ-A (minimum)
3D Secure / SCA (Strong Customer Authentication)	—	✓	Stripe handles automatically for EU transactions
Fraud detection (Stripe Radar)	—	✓	Built-in, automatic — no extra development required
Webhook reception and Signature verification	✓	—	<code>Stripe-Signature</code> header + webhook secret
Vote crediting after successful payment	✓	—	Idempotent webhook handler
Pool increment (donation pool)	✓	—	Atomic DB increment

Confirmation email	✓	—	Sharity email sending (msmtp / WP Mail)
Donation certificate (for corporate donors)	✓	—	Issued by the Sharity Foundation
Multi-currency conversion	—	✓	Stripe handles settlement (settlement currency: HUF)
Payout (disbursement to Sharity bank account)	—	✓	Stripe → Sharity bank account (automatic schedule)

2.2 Security

Area	Sharity	Stripe	Notes
Secure storage of API keys	✓	—	In environment variables, excluded from version control
Webhook secret rotation	✓	✓	Sharity is responsible for initiating rotation
SSL/TLS (communication encryption)	✓ (server)	✓ (API)	HTTPS mandatory on both sides
PCI-DSS compliance	✓ (SAQ-A)	✓ (Level 1)	Hosted checkout → Sharity scope is minimal
Rate limiting (bot protection)	✓	—	Cloudflare WAF + pseudo_id cap

Cloudflare Turnstile (CAPTCHA)	✓	—	Before checkout initiation
IP fraud monitoring	—	✓	Stripe Radar
Account takeover protection	—	✓	Stripe account-level protection

2.3 Disputes and Refunds

Activity	Sharity	Stripe	Notes
Chargeback notification	—	✓	Stripe webhook: <code>charge.dispute.created</code>
Chargeback evidence compilation	✓	—	See Dispute Handling Procedure
Chargeback evidence submission	✓	✓	Sharity uploads → Stripe forwards to the bank
Refund initiation	✓	—	Admin decision (exceptional, D6: donations are non-refundable)
Refund execution	—	✓	Stripe API: <code>Refund::create()</code>
Vote revocation on refund/void	✓	—	See Dispute Handling Procedure §4

Refund exceptions: The general rule of "donations are non-refundable" (D6) is subject to exceptions in the case of double charges and verified system errors. In such cases, Sharity initiates the refund via the Stripe API.

The checkout and GTC wording clearly set out the refund conditions so that the chargeback evidence does not contain ambiguous statements.

2.4 Compliance and Data Protection

Area	Sharity	Stripe	Notes
GDPR — data controller	✓	—	Sharity is the data controller
GDPR — data processor	—	✓	Stripe as data processor (see GDPR Data Processor Registry)
DPA (Data Processing Agreement)	✓ (signing)	✓ (provision)	Stripe DPA: https://stripe.com/legal/dpa
Transaction data retention	✓ (DB)	✓ (Dashboard)	Both parties retain — accounting obligation: 8 years
User data deletion (GDPR right)	✓	—	Sharity: soft-delete for corporate data; Stripe: retain for compliance
AML / KYC (anti-money laundering checks)	—	✓	Stripe performs (Sharity does not handle card data)

3. Stripe Contractual Terms References

Document	URL	Applies to
Stripe Services Agreement	https://stripe.com/legal/ssa	General service terms
Stripe Privacy Policy	https://stripe.com/privacy	Privacy policy
Stripe Data Processing Agreement (DPA)	https://stripe.com/legal/dpa	GDPR data processing agreement
Stripe Checkout Documentation	https://docs.stripe.com/payments/checkout	Checkout Session API reference
Stripe Disputes & Fraud	https://docs.stripe.com/disputes	Chargeback handling documentation
Stripe PCI Compliance	https://stripe.com/guides/pci-compliance	PCI-DSS levels and SAQ-A
Stripe Zero-Decimal Currencies	https://docs.stripe.com/currencies#zero-decimal	HUF/CZK handling

4. Contact Information

Matter	Handled by	How
--------	------------	-----

Stripe account settings	Sharity admin	Stripe Dashboard → Settings
Webhook configuration	Sharity developer	Stripe Dashboard → Developers → Webhooks
Stripe support (technical)	Sharity admin	Stripe Dashboard → Support (email/chat)
Chargeback response	Sharity admin	Stripe Dashboard → Payments → Disputes
Payout settings	Sharity finance	Stripe Dashboard → Balance → Payouts

5. Review

- **Frequency:** semi-annually, or upon changes to Stripe terms
 - **Responsible:** Ops Squad + CFO
 - **Mandatory update triggers:** Stripe SSA update, addition of new currencies, post-PCI audit findings
-

Changelog

Version	Date	Change
1.0	2026-02-25	Initial version — draft

1.1	2026-02-25	Finalization: removal of internal file references, audit note integration, refund exception documentation
-----	------------	---

Related Documents and Guides

- [Dispute Handling Procedure](#)
- [General Terms and Conditions \(GTC\)](#)
- [GDPR Data Processors](#)
- [Access Control Matrix](#)
- [Impact Challenge Guide](#)
- [Impact Amplifier \(About Us\)](#)